PROFESSIONAL PRACTICE PROJECT

Cybersecurity Risk Assessment Report

CedarBridge Family Health | Hypothetical Healthcare Provider

NIST SP 800-30 Rev. 1 risk assessment methodology • HIPAA-aware security recommendations

PREPARED BY	REPORT DATE	STATUS
Khadijat Badmus	October 12, 2026	Simulated / Portfolio Sample

What this project demonstrates

- Identifying cybersecurity threats and business impacts
- Prioritizing risks through a documented scoring approach
- Mapping mitigations to NIST SP 800-53 controls and healthcare security guidance
- Communicating a realistic 90-day action plan to leadership

INTEGRITY NOTE: All business details, system conditions, scores, and findings in this report are fictional and illustrative. No real healthcare organization was assessed; no live systems were tested; no patient data were accessed.

Executive Summary

CedarBridge Family Health is a fictional two-clinic outpatient provider with approximately 150 employees. For this portfolio exercise, it operates a cloud-hosted electronic health record (EHR), billing integrations, clinician workstations, mobile laptops, a remote-access solution, and shared business file services. The primary security objective is to protect electronic protected health information (ePHI) while keeping patient care available.

Using an illustrative 5 × 5 likelihood-impact model informed by NIST SP 800-30 Rev. 1, this assessment identifies 10 plausible risk scenarios: 3 Critical, 6 High, and 1 Moderate. Ratings represent hypothetical risk exposure and are not verified findings. The highest priorities are EHR credential compromise, ransomware-related interruption, and remote-access gateway exploitation.

Decisions recommended for executive leadership

- Approve a 30-day stabilization effort for MFA, remote-access hardening, endpoint defenses, and recoverable backups.
- Assign accountable risk owners, and establish decision rights for accepting residual risks after mitigation.
- Fund 60-day access governance, log review, vendor diligence, wireless segmentation, and encryption improvements.
- Ask for verifiable evidence (configuration exports, change tickets, restore results) rather than treating policy statements as proof of implementation.

Risk distribution

CRITICAL	HIGH	MODERATE	LOW
3 scenarios	6 scenarios	1 scenario	0 scenarios

Priority interpretation: the impact to patient care and ePHI can remain high even after preventive controls lower the likelihood of an event. Target residual scores are planning targets, not measured post-remediation outcomes.

1. Organization, Scope, and Assumptions

In scope

Fictional EHR access and related identities; clinical and office endpoints; local file services; remote-access infrastructure; backups; network segmentation; third-party billing data transfers; security logging; and administrative processes governing staff and vendor access.

Out of scope

Actual vulnerability scans, penetration tests, interviews, production configurations, cloud tenancy review, formal legal determinations, and a full HIPAA compliance audit. These require authorization, evidence, and organizational context.

Working assumptions

The organization is treated as a HIPAA-covered entity for the scenario; it maintains ePHI in the EHR and selected supporting systems. Potential control gaps described below are assumptions created solely for this

exercise. Exposure levels, probability estimates, costs, and deadlines should be recalibrated using actual inventory, threat intelligence, logs, and responsible stakeholders during a real assessment.

2. Assessment Methodology

This simulation follows the NIST SP 800-30 Rev. 1 sequence: prepare (define context, purpose, scope and assumptions), conduct (identify threat events, vulnerabilities, likelihood and impact), and maintain (refresh risks as the environment changes). NIST CSF 2.0 is used as a communication lens; SP 800-53 is used to illustrate relevant controls. NIST SP 800-66 Rev. 2 and HHS risk-analysis guidance inform the healthcare context.

Likelihood and impact scale

VALUE	LIKELIHOOD (ILLUSTRATIVE)	IMPACT (ILLUSTRATIVE)
1	Rare / unlikely within planning horizon	Negligible disruption; minor data concern
2	Unlikely but plausible	Limited business interruption or localized exposure
3	Possible given common attack patterns	Material service interruption; reportable incident possible
4	Likely absent stronger controls	Major operational disruption or sensitive-data event
5	Very likely / repeatedly expected	Severe, prolonged patient-care or ePHI consequences

Scoring and decision rules

Inherent score = Likelihood (1–5) × Impact (1–5). Low = 1–4; Moderate = 5–9; High = 10–16; Critical = 17–25. Impact includes confidentiality, integrity, availability, patient care, legal exposure, and operational cost. Qualitative assumptions are converted into scores for triage; these numbers are not validated probabilities.

Target residual score uses the same formula after proposed treatment. A lower target impact is justified only when a mitigation such as tested recovery or access minimization could reasonably contain consequences. Leadership should approve changes to impact assumptions based on evidence, not on the mere existence of a planned control.

Risk handling process

- Propose: Identify assets, threats, assumed weaknesses, and plausible consequences.
- Evaluate: Rate likelihood and impact, then prioritize inherent risk.
- Treat: Recommend preventive, detective, and recovery controls; assign owner and target date.
- Validate: Collect evidence, test selected controls, and rescore residual risk.
- Govern: Escalate unaccepted residual High/Critical risks and review the register at least quarterly or after a major change.

Risk acceptance criteria (proposed)

Critical: immediate leadership escalation and prompt interim protections. High: documented remediation plan with owner and deadline; executive acceptance required for deferral. Moderate: assign a response owner and track to closure. Low: monitor periodically. These are example governance rules—not regulatory requirements or a confirmed CedarBridge policy.

3. Risk Register - Leadership View

The complete, editable register appears in the accompanying risk_register.csv. The following table shows inherent severity and an illustrative target after controls are applied.

ID	SCENARIO	INHERENT	RATING	TARGET	OWNER
R-01	Phishing-led EHR credential compromise	20 (4×5)	Critical	10 (2×5)	IT/Security
R-02	Ransomware disrupts clinical operations	20 (4×5)	Critical	10 (2×5)	IT Operations
R-03	Compromised remote-access gateway	20 (4×5)	Critical	10 (2×5)	Network Lead
R-04	Excessive access to patient records	15 (3×5)	High	8 (2×4)	Compliance/IAM
R-05	Unrecoverable backup during outage	15 (3×5)	High	8 (2×4)	IT Operations
R-06	Lost laptop exposes ePHI	12 (3×4)	High	4 (1×4)	Endpoint Admin
R-07	Billing vendor incident affects patient data	12 (3×4)	High	8 (2×4)	Vendor/Privacy
R-08	Delayed detection of unauthorized access	12 (4×3)	High	6 (2×3)	Security Lead
R-09	Unlocked workstation in clinical area	8 (2×4)	Moderate	4 (1×4)	Clinic Operations
R-10	Guest Wi-Fi reaches internal systems	12 (3×4)	High	4 (1×4)	Network Lead

Note: Scores are synthetic inputs. The scenario narrative, assumptions, control proposals, evidence expectations, and target windows are provided below and in the CSV. The risk register status for every row is "Proposed (simulated)."

Highest-priority exposure pathways

Identity attack: phishing can lead to a compromised EHR account and unauthorized access to ePHI. Availability attack: ransomware or backup failure can delay treatment and scheduling. Perimeter attack: unpatched remote access may provide a foothold into internal services. Together, these justify prioritizing strong authentication, hardening, segmentation, and tested recovery before lower-consequence improvements.

4. Detailed Risk Scenarios and Treatments

Each item below is a hypothetical scenario, not a claim that the named control is missing from an actual environment. NIST control IDs are illustrative alignments; organizations must select controls appropriate to their risk profile.

R-01 | Phishing-led EHR credential compromise — Critical

Exposure pathway: Credential phishing and account takeover. Planning assumption: Assumed limited phishing-resistant MFA and inconsistent user training. Primary asset: EHR SaaS and patient records.

Treatment: Deploy phishing-resistant MFA for privileged and remote access; enforce conditional access; run quarterly simulations and targeted retraining.

Owner: IT/Security | Timing: 0-30 days | NIST SP 800-53 examples: IA-2, AT-2, AC-2 | Target residual: 10 (High)

Proposed verification: MFA configuration export; enrollment coverage; training completion.

R-02 | Ransomware disrupts clinical operations — Critical

Exposure pathway: Ransomware via endpoint or malicious attachment. Planning assumption: Assumed inconsistent endpoint isolation and restore testing. Primary asset: File services, endpoints, scheduling.

Treatment: Harden endpoints, limit lateral movement, deploy EDR where appropriate, keep immutable/offline backups, and conduct a restore exercise.

Owner: IT Operations | Timing: 0-30 days | NIST SP 800-53 examples: SI-3, CP-9, CP-4, IR-4 | Target residual: 10 (High)

Proposed verification: EDR coverage report; backup inventory; restore-test record.

R-03 | Compromised remote-access gateway — Critical

Exposure pathway: Exploitation of exposed VPN or remote-access software. Planning assumption: Assumed patch delays and broad remote access. Primary asset: Remote access and clinical network.

Treatment: Inventory exposed services; apply priority patches; require MFA; restrict privileged remote access; review access logs daily during stabilization.

Owner: Network Lead | Timing: 0-30 days | NIST SP 800-53 examples: SI-2, IA-2, SC-7 | Target residual: 10 (High)

Proposed verification: External-service inventory; patch records; remote-access policy.

R-04 | Excessive access to patient records — High

Exposure pathway: Inappropriate access, error, or misuse. Planning assumption: Assumed manual joiner-mover-leaver process and stale accounts. Primary asset: EHR accounts and role permissions.

Treatment: Create role-based access profiles; reconcile HR and EHR accounts; disable departures promptly; perform quarterly access reviews.

Owner: Compliance/IAM | Timing: 31-60 days | NIST SP 800-53 examples: AC-2, AC-3, AC-6 | Target residual: 8 (Moderate)

Proposed verification: Access review signoffs; deprovisioning tickets; RBAC matrix.

R-05 | Unrecoverable backup during outage — High

Exposure pathway: Corruption, ransomware, or backup failure. Planning assumption: Assumed backup jobs exist but recovery objectives are untested. Primary asset: EHR exports, file shares and recovery data.

Treatment: Set recovery-time and recovery-point objectives; separate backup credentials; verify daily alerts; test sample restores monthly.

Owner: IT Operations | Timing: 0-30 days | NIST SP 800-53 examples: CP-9, CP-4, CP-2 | Target residual: 8 (Moderate)

Proposed verification: Backup success trends; restore log; approved RTO/RPO.

R-06 | Lost laptop exposes ePHI — High

Exposure pathway: Device theft or loss. Planning assumption: Assumed incomplete full-disk encryption and asset inventory. Primary asset: Clinician laptops and cached records.

Treatment: Enforce full-disk encryption and screen locks, centralize device inventory, and enable remote wipe for managed endpoints.

Owner: Endpoint Admin | Timing: 31-60 days | NIST SP 800-53 examples: SC-28, CM-8, MP-5 | Target residual: 4 (Low)

Proposed verification: Encryption compliance report; endpoint inventory.

R-07 | Billing vendor incident affects patient data — High

Exposure pathway: Third-party compromise or insecure data transfer. Planning assumption: Assumed limited security due diligence and incomplete data-flow inventory. Primary asset: Billing interface and vendor data flows.

Treatment: Confirm business associate agreements where required; document data flows; assess critical vendor controls; set notification expectations.

Owner: Vendor/Privacy | Timing: 31-60 days | NIST SP 800-53 examples: SR-3, SA-9, CA-3 | Target residual: 8 (Moderate)

Proposed verification: Vendor inventory; BAA register; due-diligence worksheet.

R-08 | Delayed detection of unauthorized access — High

Exposure pathway: Abnormal activity remains unnoticed. Planning assumption: Assumed decentralized logging and no assigned review cadence. Primary asset: EHR audit logs and security alerts.

Treatment: Aggregate high-value EHR, identity and remote-access logs; define daily triage and incident escalation; document alert ownership.

Owner: Security Lead | Timing: 31-60 days | NIST SP 800-53 examples: AU-6, AU-12, IR-4 | Target residual: 6 (Moderate)

Proposed verification: Log-source matrix; alert tickets; review SOP.

R-09 | Unlocked workstation in clinical area — Moderate

Exposure pathway: Unauthorized viewing after staff step away. Planning assumption: Assumed inconsistent automatic locking and local workstation practices. Primary asset: Shared workstations and patient portal sessions.

Treatment: Configure short auto-lock timeouts, enforce unique accounts, conduct spot checks, and reinforce workstation privacy expectations.

Owner: Clinic Operations | Timing: 61-90 days | NIST SP 800-53 examples: AC-11, IA-2, AT-2 | Target residual: 4 (Low)

Proposed verification: Workstation baseline; inspection checklist; training roster.

R-10 | Guest Wi-Fi reaches internal systems — High

Exposure pathway: Guest-origin lateral movement or accidental exposure. Planning assumption: Assumed insufficient guest/clinical network segregation. Primary asset: Wireless network and clinical endpoints.

Treatment: Place guest wireless on isolated VLAN/network; deny internal routes; validate segmentation with authorized test cases and change records.

Owner: Network Lead | Timing: 31-60 days | NIST SP 800-53 examples: SC-7, CM-6, CA-8 | Target residual: 4 (Low)

Proposed verification: Network diagram; firewall rules; segmentation test results.

5. 90-Day Remediation Roadmap

The schedule below is a proposed management plan for a hypothetical organization. It assumes executive sponsorship, assigned technical ownership, and a change-control process. Actual dates depend on capacity and vendor lead times.

WINDOW	ACTION PACKAGE	EXIT EVIDENCE
Days 0–30	Enforce MFA on remote/privileged access; patch exposed services; prioritize endpoint response coverage; verify backup restorability.	MFA adoption report, patch/change records, EDR coverage, one successful restore test
Days 31–60	Review EHR permissions and offboarding; encrypt laptops; implement essential event monitoring; validate guest-network separation; assess critical billing vendors.	Access-review approvals, encryption inventory, log review tickets, firewall tests, vendor files
Days 61–90	Complete workstation auto-lock baseline, staff refresh training, recovery tabletop exercise, and re-score risks with evidence.	Baseline attestation, training roster, tabletop after-action report, approved revised register

Suggested performance measures

- Privileged and remote users covered by strong MFA: target 100% by Day 30.
- Critical exposed-system patches completed within organization-approved service levels; exceptions documented.
- Critical backup datasets with verified restore: target 100% of defined recovery scope by Day 60.
- Terminated users disabled within the approved offboarding SLA; report exceptions weekly.
- Critical identity, EHR and remote-access log sources represented in review workflow: target 100% by Day 60.

Governance and escalation

The Security Lead updates a risk register weekly during stabilization and monthly thereafter. Owners retain remediation evidence. Compliance/Privacy reviews risks that may affect ePHI, while leadership adjudicates residual risk acceptance and resource needs. A security incident, new exposed service, major vendor change, or failed recovery test triggers out-of-cycle reassessment.

6. Control Alignment and Evidence Plan

Control mappings are illustrative; they do not certify HIPAA compliance. The HIPAA Security Rule requires appropriate safeguards and a risk analysis proportionate to an organization's environment. NIST SP 800-66 Rev. 2 is a resource for interpreting and implementing those activities.

CONTROL THEME	EXAMPLES OF NIST CONTROLS	WHAT WOULD COUNT AS EVIDENCE
Identity and least privilege	IA-2; AC-2; AC-6	MFA enforcement policies; account lifecycle tickets; role review approvals
Vulnerability / network security	SI-2; SC-7; CM-6	Patch exceptions; segmentation diagrams; approved firewall rule set
Monitoring and response	AU-6; IR-4	Daily alert review log; incident exercise; escalation procedure

CONTROL THEME	EXAMPLES OF NIST CONTROLS	WHAT WOULD COUNT AS EVIDENCE
Recovery and resilience	CP-9; CP-4; CP-2	Restore results, backup inventory, tested recovery objectives
Workforce and endpoint protection	AT-2; SC-28; AC-11	Training roster, disk-encryption coverage, screen-lock baseline
Vendor oversight	SR-3; SA-9	Vendor risk assessment, contracts/BAAs where applicable

7. Validation Plan, Limitations, and Next Steps

How a real assessor would validate this work

- Obtain written assessment authorization and confirm the complete ePHI data flow and system inventory.
- Review EHR access permissions and sign-in policies, preserving screenshots or exports without exposing patient data.
- Inspect patch reports, remote-access settings, backup configurations, change tickets, and documented restoration tests.
- Interview IT, security, operations, billing, and privacy stakeholders to verify design versus operation.
- Compare evidence to policy and applicable legal obligations; update likelihood, impact, owners, and residual scores.

Key limitations

This report contains no empirical testing, attack execution, discovery scan, interviews, or verified control failures. Ratings are analyst-created examples rather than measured organizational risk. The control mapping is selective, not a complete implementation checklist. It is not a Security Rule compliance determination, legal advice, an audit opinion, or an assessment of any existing healthcare entity.

Portfolio skills demonstrated

Risk methodology documentation; asset and threat modeling; likelihood/impact prioritization; risk-register maintenance; recommendations aligned to recognized frameworks; evidence planning; 30/60/90-day remediation governance; and executive-facing communication.

8. References

Marron, J. (2024). Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A cybersecurity resource guide (NIST SP 800-66 Rev. 2). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-66r2

National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). https://doi.org/10.6028/NIST.CSWP.29

National Institute of Standards and Technology. (2020, updated 2025). Security and privacy controls for information systems and organizations (NIST SP 800-53 Rev. 5). https://doi.org/10.6028/NIST.SP.800-53r5

Ross, R. (2012). Guide for conducting risk assessments (NIST SP 800-30 Rev. 1). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-30r1

U.S. Department of Health and Human Services, Office for Civil Rights. (n.d.). Guidance on risk analysis. https://www.hhs.gov/hipaa/for-professionals/security/guidance/guidance-risk-analysis/index.html

U.S. Department of Health and Human Services, Office for Civil Rights. (n.d.). Summary of the HIPAA Security Rule. https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html